

B U P T

密码工程

第12讲、密钥服务器、PKI

授课教师：王晨宇

时间：2026年6月14日



5.4

密钥服务器



密钥服务器

B U P T



- ✓ 5.4.1 基本概念
- ✓ 5.4.2 Kerberos
- ✓ 5.4.3 改进方案
- ✓ 5.4.4 选择



- 密钥管理是系统中最困难的问题。
- 在工程领域的密码学研究中，核心讨论范畴主要涵盖加密机制的设计与分析、数据完整性认证技术的构建、身份识别方案的优化以及通信双方共享密钥的协商协议研究。
- 在构建Alice与Bob的身份认证方案时，我们将面临复杂的技术挑战。其中，密钥管理机制的设计尤为关键且极具挑战性，因其不仅涉及密码学的数学理论，更需纳入人类行为因素——后者所带来的不确定性与不可预测性，使得密钥管理成为兼具技术属性与社会属性的交叉研究难题。



- ❑ 密码学视角的密钥管理涉及密钥分发协议设计（如公钥基础设施传输机制）、密钥权限约束模型（如属性加密访问控制）、持有者身份验证方法（如零知识证明身份确认）、存储保护技术（如安全多方计算分片存储）及生命周期验证机制（如哈希链有效性验证）等。
- ❑ 上述技术问题的解决方案与组织需求解耦（组织架构差异带来的策略性需求，如权限层级、合规性要求等）属于管理科学范畴，不纳入本次密码学技术讨论。
- ❑ 密钥管理的一个办法是让一个可信实体来分发所有的密钥，我们把这个实体叫做密钥服务器。



- 密钥建立协议：它能够为两个或多个参与方生成共享密钥，供随后的密码方案使用。
- 生成的共享密钥，常用于推导会话密钥。
- 协议是一系列步骤，至少需要两方参与，其设计的目的是要完成一项任务。
 - 协议是从开始到结束的一个序列，每步必须依次执行
 - 完成协议至少需要两方参与
 - 协议设计的目的是为了完成任务



- 密钥建立协议可分为：
- 密钥传输协议：在该协议中，其中一个参与方可以建立或获得一个秘密值，并将它安全地传输给其他参与方。
- 密钥协商协议：两个（或更多的）参与方共同提供消息，推导出一个共享密钥，（理想状态下）任何一方不能预先确定结果值。

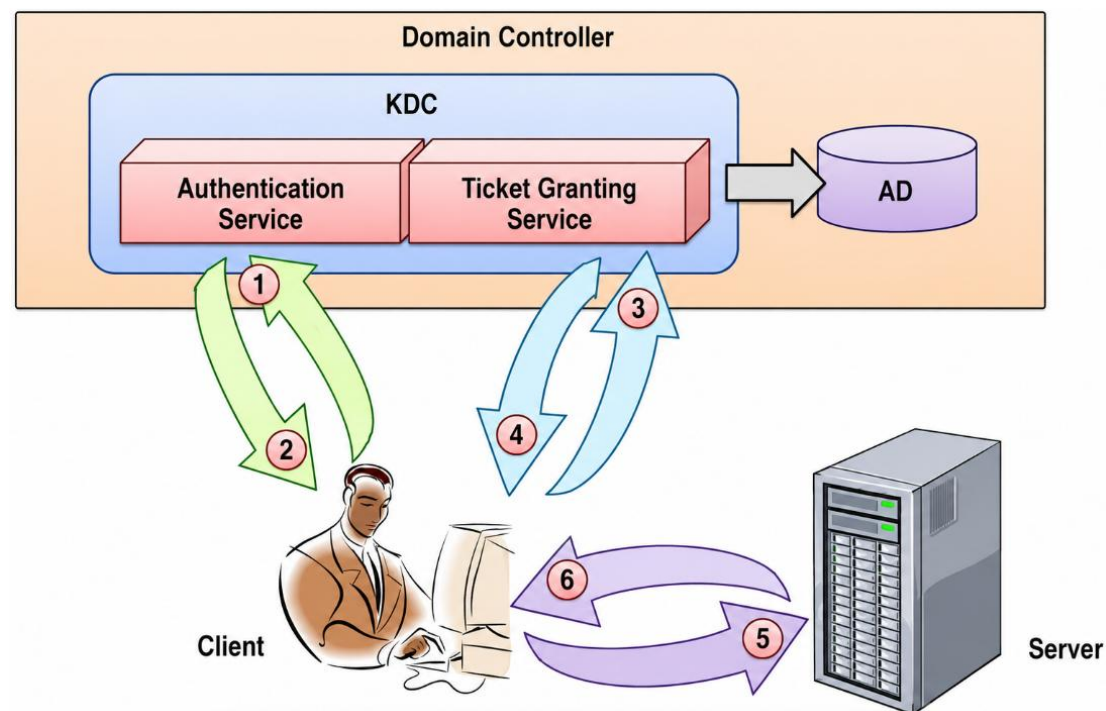


➤ Kerberos认证

Kerberos是为TCP/IP网络系统设计的可信的第三方认证协议。

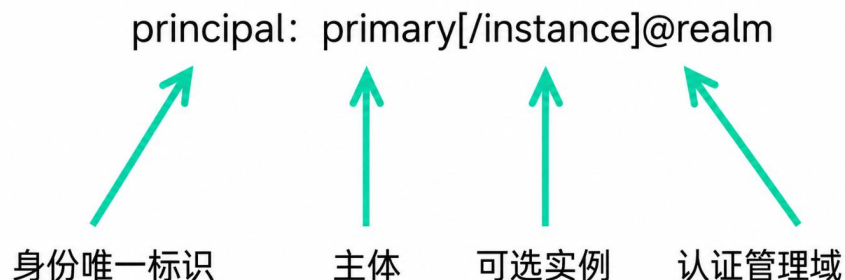
➤ Kerberos基本概念

- KDC (Key Distribution Center): 密钥分发中心
- AD(account database): 存储认证信息
- Authentication Service: 验证用户身份, 发放TGT
- TGT(Ticket Granting Ticket): 票据授予票
- Ticket Granting Service: 验证TGT换取ST
- ST(Service Ticket): 访问对应服务的票据





- **step1:** 客户端通过principal和密码或Keytab访问Authentication Service申请鉴权。

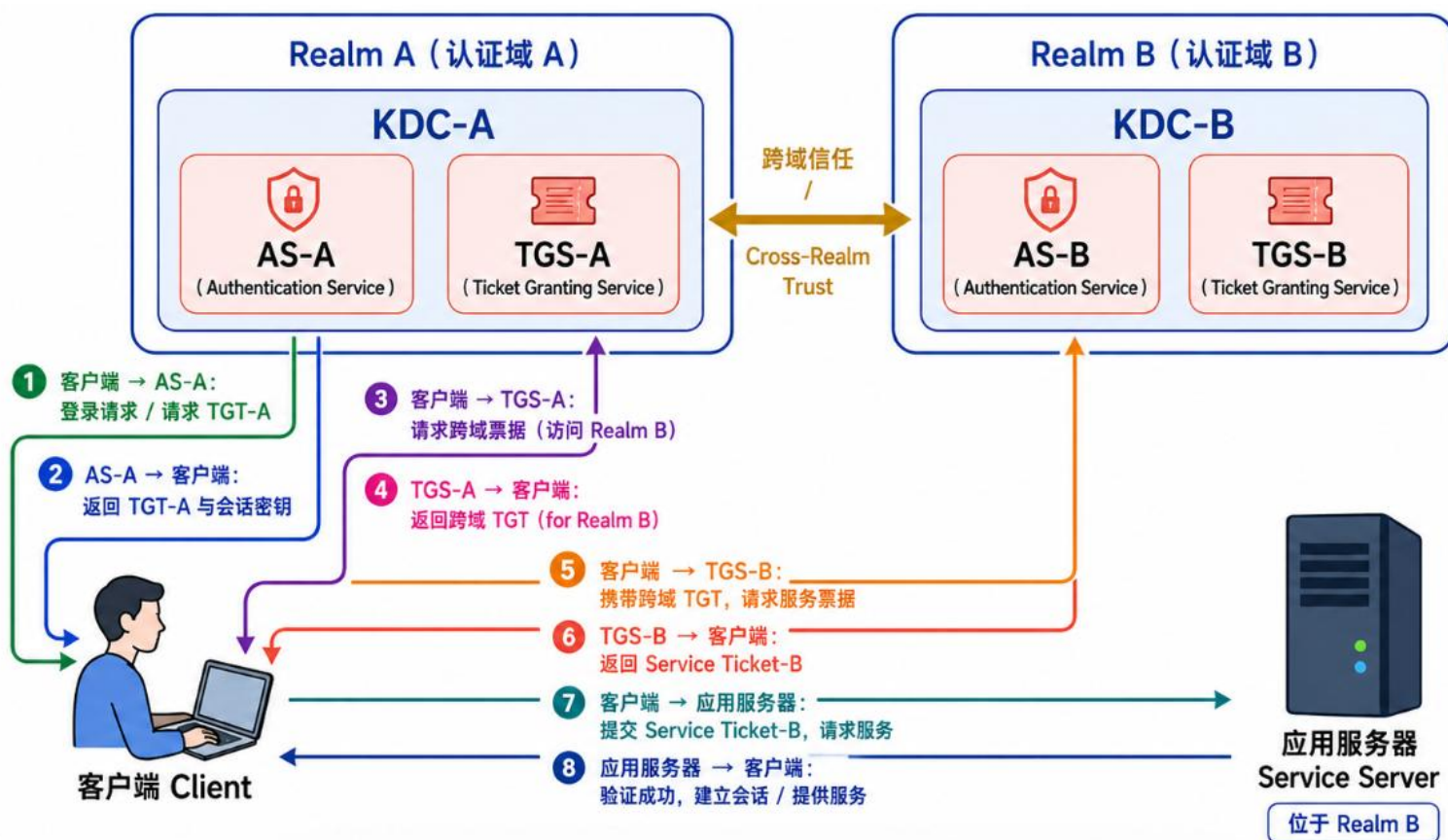


-principal相当于用户名，一般的形式是name/instance@realm或者name@realm，name是用户名或者服务名，instance用来对用户名或服务名进行限定，realm用于区分principal所在的kerberos数据库，Keytab保存了用户的一个或多个密码信息。

- **step2:** Authentication Service验证客户端的身份，通过后会发放 TGT (Ticket Granting Ticket)。
- **step3:** 客户端使用TGT向Ticket Granting Service发起请求，申请对应服务的鉴权Ticket Granting Service验证通过后发放ServiceTicket。
- **step4:** 客户端使用ServiceTicket访问对应服务，完成鉴权。



➤ 多区域的Kerberos





➤ 黄金票据攻击 (Golden ticket attack)

在 Windows 的 kerberos 认证过程中, Client 将自己的信息发送给 KDC, 然后 KDC 使用 A 用户的 NTLM-Hash 作为密钥进行加密, 生成 TGT。那么如果获取到了 A 用户的 NTLM-Hash 值, 就可以伪造任意的 TGT。因为 Krbtgt 只有域控制器上面才有, 所以使用黄金凭据意味着你之前拿到过域控制器的权限, 黄金凭据可以理解为一个后门。

先假设这么一种情况, 原先已拿到的域内所有的账户 Hash, 包括 A 用户这个账户, 由于有些原因导致你对域管权限丢失, 但好在你还有一个普通域用户权限, 碰巧管理员在域内加固时忘记重置 A 用户密码, 基于此条件, 我们还能利用该票据重新获得域管理员权限。利用 A 用户的 Hash 值可以伪造生成任意的 TGT, 能够绕过对任意用户的账号策略, 让用户成为任意组的成员, 可用于 Kerberos 认证的任何服务。

➤ 白银票据攻击 (Silver ticket attack)

白银票据不同于黄金票据, 白银票据的利用过程是伪造 TGS, 通过已知的授权服务密码生成一张可以访问该服务的 TGT。因为在票据生成过程中不需要使用 KDC, 所以可以绕过域控制器, 很少留下日志。而黄金票据在利用过程中由 KDC 颁发 TGT, 并且在生成伪造的 TGT 得 20 分钟内, TGS 不会对该 TGT 的真伪进行检验。白银票据依赖于服务账号的密码散列值, 这不同于黄金票据利用需要使用 A 用户账号的密码哈希值, 因此更加隐蔽。

[视频: 深入理解黄金票据攻击](#)



整个kerberos认证的过程较为复杂，三次通信中都使用了密钥，且密钥的种类一直在变化，并且为了防止网络拦截密钥，这些密钥都是临时生成的Session Key，即他们只在一次Session会话中起作用，即使密钥被劫持，等到密钥被破解可能这次会话都早已结束。

- 密码无需进行网络传输：基于 Ticket 实现身份认证，保障密钥安全性。
- 双向认证：整个认证过程中，不仅需要客户端进行认证，待访问的服务也需要进行身份认证。
- 高性能：一旦Client获得用过访问某个Server的Ticket，该Server就能根据这个Ticket实现对Client的验证，而无须KDC的再次参与。



- 由于Kerberos的协议太复杂而且存在限制，因此它并不是普适的，例如服务器需要存储所有的用户密钥，而且每个用户还需要一个**可靠的时钟**。这些要求在某些特定场景下是无法满足的。
- 为了提升Kerberos的效率，研究人员做了诸多改进。其中一种方案允许密钥服务器维持状态。
- 由于计算机技术的进步，该方案可以维持上万个用户的状态。



- 改进的Kerberos方案也能够应用于复杂系统。假设有一个存在10万个用户的系统，如果每个用户在密钥服务器中需要占1KB，那么存储所有的状态仅需要1亿($<2^{32}$)字节的内存。
- 改进方案的密钥服务器需要很快的建立所有请求的密钥，但对现代的快速的计算机来说也是很容易实现的。
- 考虑到密钥的安全性，密钥服务器一般不会有上万个用户。
- 我们假设密钥服务器不超过几千个用户，接下来我们介绍改进的Kerberos方案。



- 第一步是建立安全连接。
- 首先，我们假定Alice和密钥服务器共享密钥 K_A 。用这个密钥来运行密钥协商协议，协商建立的新密钥是 K'_A 。所有其他用户也都与密钥服务器运行同样的协议，建立新的密钥。
- Alice和密钥服务器产生一个安全的通信信道，该信道提供私密性、可认证性、重放保护等特性，使用这个信道可以进行安全的通信。所有进一步通信都发生在这个安全的信道上。同样地，其他用户也与密钥服务器建立一个安全信道。



- 接下来是建立Alice和Bob之间的密钥。
- 因为安全信道已经防止了其他类型的攻击，只需要考虑信息丢失或被攻击者删除的情况。Alice请求密钥服务器来建立他和Bob之间的密钥，密钥服务器把新密钥 K_{AB} 发送给Alice和Bob作为答复
- 密钥服务器甚至可以通过Alice把信息传送给Bob，而无需直接与Bob通信。



- K'_A 必须有一个有限的使用期。
- 定时更新和销毁密钥是可以做到的，因为Alice可以重新运行密钥协商协议来得到新的 K'_A 。
- 因为密钥能够重新生成，密钥服务器不必以可靠的方式来存储安全通信状态。
- 假定密钥服务器出现事故，丢失了所有的状态信息，但只要 K_A 没有丢失就没有问题，密钥服务器与每个用户之间重新运行密钥协商协议。因此，虽然密钥服务器不是无状态的，但当运行协议时它不必修改自己的长期状态。



- 从理论上的步骤来看该方案相比于Kerberos简单很多。安全信道的存在使得抵抗针对于协议的可能攻击更加容易。
- 但密码学是一直在发展的，该方案的一个密钥服务器的假设在将来会被淘汰。同时可以看出，设计一个好的密钥管理系统的主要工作是需要收集特定应用的具体需求并且得到完好的用户界面。



- 由于Kerberos技术业已成熟，在大多数情况下仍会使用Kerberos。
- 但在一些不适合使用Kerberos的场景下，我们需要设计或者直接应用一些其他方案(比如我们刚才阐述的方案)。
- 如何设计密钥服务系统是这些其他方案中的主要操作。针对于大多数当前已经有的密码学相关应用，在密钥服务器系统上花费的时间至少应该与整个应用运行的时间一样多。



1. Kerberos有什么优点？存在什么问题？



5.5

PKI



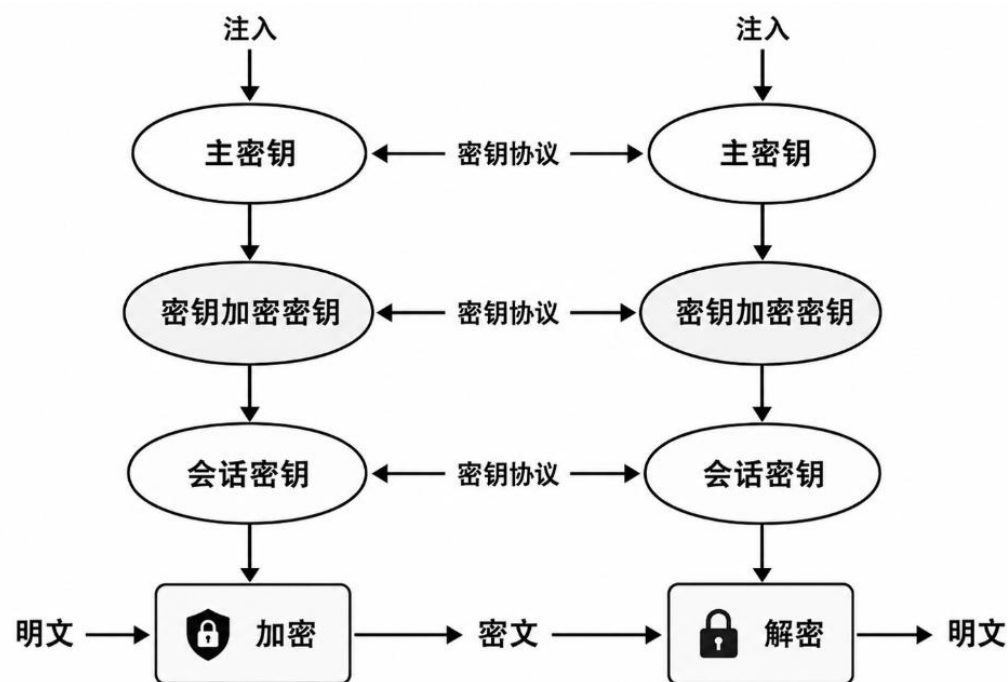
- ✓ 5.5.1 PKI的简短回顾
- ✓ 5.5.2 PKI的例子
- ✓ 5.5.3 其它细节
- ✓ 5.5.4 结论



- PKI, 即公钥基础设施 (Public Key Infrastructure), 是一种遵循既定标准的密钥管理平台, 能够为所有网络应用提供加密和数字签名等密码服务及所必需的密钥和证书管理体系。
- 简单来说, PKI就是利用公钥理论和技术建立的提供安全服务的基础设施, 是信息安全技术的核心, 也是电子商务的关键和基础技术。
- PKI技术旨在为网络通信和网络交易, 尤其是电子政务和电子商务业务, 透明地提供一整套安全服务, 主要涵盖身份认证、保密、数据完整性和不可否认性。身份认证确保参与网络活动的各方身份真实可靠; 保密性防止数据在传输和存储过程被窃取; 数据完整性防止数据被篡改, 确保接收的数据与发送时一致; 不可否认性则防止交易双方事后否认交易行为。



- 整个密码体制的安全性取决于密钥的保密性，核心问题是密钥管理问题。
- 按照密钥的生存周期、功能和保密级别，可以将密钥分为3类：**会话密钥**、**密钥加密码钥**和**主密钥**。主密钥通过某种密码算法保护密钥加密码钥，再使用密钥加密码钥通过某种密码算法保护会话密钥。





- 公钥密码体制理论上比对称密码体制更安全，但产生了新的问题：**如何确定公钥到底属于谁以及私钥丢失后该怎么做。**
- 为了解决第一个问题建立了PKI；但第二个问题目前尚没有特别好的方法。有望解决第二个问题的IBE技术尚不成熟，而PKI处理密钥丢失存在问题。
- PKI利用公钥认证确认公钥属于哪个用户。



□ PKI技术旨在为网络通信和网络交易透明地提供一整套安全服务，主要涵盖身份认证、保密、数据完整性和不可否认性。

- 身份认证确保参与网络活动的各方身份真实可靠；
- 保密保证数据在传输和存储过程中的机密性，防止被窃取；
- 数据完整性防止数据被篡改，确保接收的数据与发送时一致；
- 不可否认性则防止交易双方事后否认交易行为。

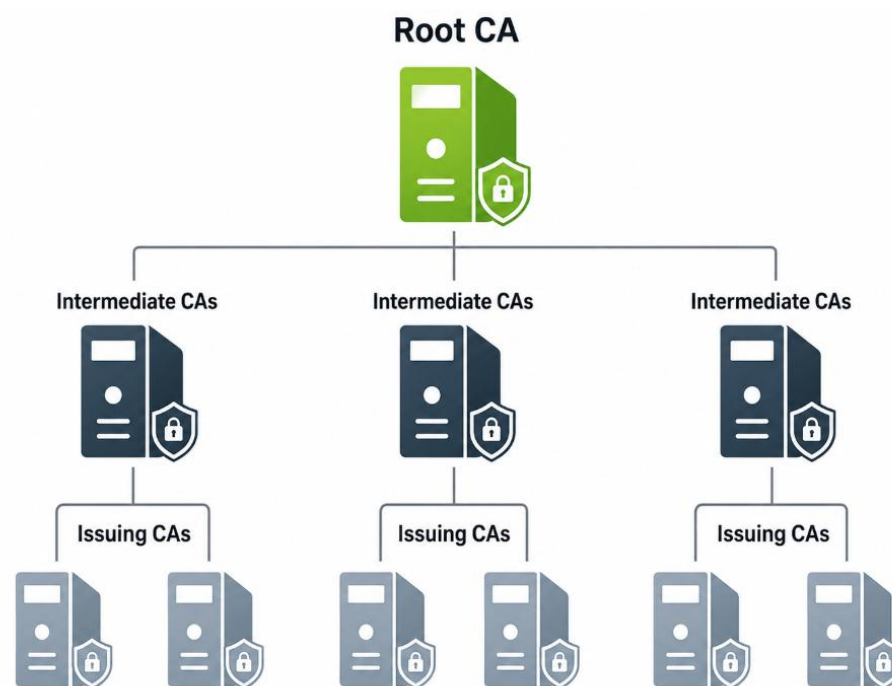


- 证书颁发机构CA：CA是PKI的核心组件，负责颁发、管理数字证书。在颁发证书前，CA会对申请者的身份和相关信息进行审核，只有通过审核的申请者才能获得证书。CA通过数字签名来保证证书的真实性和完整性，确保证书被信任。
- 注册机构RA：RA负责收集用户的身份信息，并对这些信息进行初步验证，然后将验证通过的信息提交给CA，同时提出证书请求。在整个数字证书颁发过程中，RA起到了收集用户信息和确认用户身份的重要作用。
- 数字证书库：数字证书库用于存储和分发数字证书，用户可以随时访问证书库获取所需的证书，并验证证书的有效性。证书库通常使用LDAP等协议和技术来实现证书的安全分发和访问，确保证书在传输和存储过程中的安全性。



□ PKI 是 公 钥 基 础 设 施 （ Public-Key Infrastructure），它是提供公钥加密和数字签名服务的系统或平台，目的是为了管理密钥和证书。

□ PKI有一个中央权力机构称为Certificate Authority，简称CA。CA有一公/私密钥对（例如RSA密钥对），并且对外公布公钥。我们假定每个参与方都知道CA的公钥。





- 为了加入PKI, Alice生成自己的公/私钥对, 然后把公钥 PK_A 传给CA, CA证实Alice的身份后签署证书, 证书可以用来证实密钥属于Alice。
- 如果Alice想要与Bob通信, 她就把自己的公钥和证书发给Bob。Bob有CA的公钥, 因此Bob能验证证书的签名。只要Bob相信CA, 他就会相信 PK_A 属于Alice。



- 通过同样的过程，Bob得到由CA签署的公钥证书，并且可以把公钥和证书传给Alice。这些公钥可以用于运行密钥协商协议，以建立安全通信的会话密钥。
- 现在需要的是使每个用户都信任CA。每个用户需要得到有证书的公钥，并且还需要知道CA的公钥，每个用户都可以同其他所有用户安全的进行通信。



- 我们的最终目标就是拥有一个万能的PKI，它可以给每个用户发行公钥证书，每个用户仅需要获得一次证书，因为同样的公钥可以用在每个应用中。
- 在这种理想情况下，每个人都信任PKI或成为通用CA的其他组织，这样所有参与方都可以互相安全通信。
- 但从来就没有万能的PKI，而且永远也不会有。



- 接下来介绍一些关于PKI的实例。
- 进入VPN：有VPN的公司允许员工从外部进入公司的网络。VPN的进入点必须能识别要进入网络的人以及他们有何种确切的进入级别。公司的IT部门扮演CA的角色，给每个雇员一个证书，使得VPN的进入点能够识别雇员。
- 电子银行：银行允许客户进行网上交易，在网上银行中正确的识别客户的身份是至关重要的。银行本身是CA，它能证实客户的公钥。



- 提炼传感器：提炼物质的过程会在管子和接口之间放置上百个传感器，可以测量温度、流率和压力之类的指标。
- 在提炼过程中篡改传感器数据是一种很恶劣的攻击，把错误的传感器数据发送到控制室会导致发生重大事故，因此控制室得到正确的数据是很必要的。
- 我们可以用标准的认证技术来保证传感器数据没有被篡改，但是为了确认数据来自传感器就需要PKI来参与。公司可以作为CA，对所有的传感器建立PKI，使得每个传感器都能识别控制器。



- 信用卡组织：信用卡组织是遍布世界的几千个银行之间带有风险的合作组织。所有这些银行必须能够交换支付，即在银行A有信用卡的用户必须能把钱付给在银行B开户的商人。
- 银行A与银行B需要以某种方式处理这一交易，而且保证安全。
- PKI就可以让所有的银行彼此识别身份以进行安全的交易。在这种情况下，信用卡组织扮作CA，给每个银行发行证书。



- 实际情况会更加复杂，因此PKI被扩展为各种形式。
- 在很多情况中，CA被分成多个层。例如，中心信用卡组织不直接给每个银行发行证书。相反，他们有区域性机构来管理银行。这样就得到一个两层的证书结构。中心CA签署关于区域CA公钥的证书，证实密钥 PK_X 属于区域机构X，这个证书还可以用来证实其他密钥。每个区域机构能够给单个银行发行证书。银行的密钥证书包含两个签名的消息：中心CA证实区域机构密钥的授权消息和区域机构关于银行密钥的证书。
- 上述例子中的情况叫做证书链，这样的链可以扩展到任意多的层。



- 多层证书结构在实际情况中很有效，而且对大多数组织来说把CA功能分层很容易。
- 但多层结构的PKI也存在一些缺点，其中一个缺陷是证书变得更加复杂，验证需要更多的计算。另一个缺陷就是加入系统的每个CA都会带来新的攻击点，降低了整个系统的安全性。



- 针对多层证书的缺陷提出了一些解决办法，其中一个解决办法是打破证书的层次。例如，一旦银行有了两层的证书，他就把证书送到中心CA。中心CA对两层证书做验证，然后就用CA主密钥签署一个银行密钥的单个证书。
- 如果层次像这样被打破，那么加入额外层次的代价会变得很小。但是多层次结构也会使整体系统效率大打折扣。



- 证书链结构的复杂性有所提升，但复杂性的提升也带来了一些问题。
- 互联网上的安全站点采用PKI系统已允许浏览器识别正确的网址。由于大多数用户不能求证正在使用的网址的名字，因此对于用户来说这些站点并不安全。
- 在微软操作系统中验证证书的库里出现过一个致命的bug，证书链中每个元素包含一个标识，用它来说明元素所验证的密钥是否为CA密钥，CA密钥能证实其他的密钥，非CA密钥不能证实其他的密钥，但有问题的库不能检查这个标识。



- 利用上述漏洞攻击者能购买域 nastyattacker.com 的证书，用它来给 amazon.com 签署证书，而微软IE将接受攻击者伪造的Amazon密钥的证书。
- 从上述例子可以看出，一个小bug可以毁掉整个系统安全，花费很多精力构建的世界范围安全系统被一个库里的一个简单的bug攻破，造成严重的后果。
- 虽然微软官方已经修复了这个问题，但现在仍然有人还在使用没有打补丁的版本。



- 因为密钥总是存在被攻破的风险，所以没有一种密钥能够被无限期地使用。
- 定期的密钥更换能缓解密钥泄露问题，但这种做法效率很低。
- 一个证书也不能永远有效，因为CA密钥和被证实的公钥都有截止期。即使不考虑密码学方面的原因，因为保持信息的更新而设置有效期也是很重要的。



- 当一个证书到期时，新的证书就会被重新发布，证书的信息也会相应的更新。证书的有效期一般是在几个月到几年之间。
- 几乎所有的证书系统都包含截止日期和时间，证书过期后就会作废，这也是PKI用户需要时钟的原因。



- 证书的设计还包含其他数据。证书中除了截止日期，还有起始日期，有的还包含证书的类别、证书序列号、发行日期和时间等。
- 证书最通用的模式是X.509 v3。X.509证书含有公钥和标识（主机名、组织或个人），并由证书颁发机构（CA）签名（或自签名）。对于一份经由可信的证书签发机构签名（或者可以通过其它方式验证）的证书，证书的拥有者就可以用证书及相应的私钥来创建安全的通信，以及对文档进行数字签名。



- 在一些情况下，子系统需要包含一个独立的注册机构。例如公司里只有HR部门才能决定谁是雇员，但假设IT部门由于一些技术要求需要运行CA的话，它不会去专门请求HR部门。
- 以上情况有两种比较好的解决办法。第一种是使用多层证书结构，让HR部门成为子CA，自动提供必须的灵活性来支持多机构。第二种办法与第一种类似，即一旦用户有了两层证书，他就能从中心CA得到一层的证书，只需要把两个消息协议加入系统，就排除了每次使用时检查两层证书的负担。



- 第三个不太好的解决方案是把第三方加入到密码协议中，即在CA之外加入叫做RA（注册结构）的另一方。
- CA和RA被看作完全独立的实体，加入RA的话不仅会使系统变得臃肿繁琐，而且还会增加必要的说明。因此这种方法不可取。



- 甚至有RA授权CA发行证书的三方协议。这种方法虽然欠妥，但是这种方法实现了用户需求施加到技术解决方案上的需求。
- 用户需求仅仅说明了系统的外部行为，公司的HR部门和IT部门需要有独立的功能。但这并不意味着软件对HR部门和IT部门有不同的代码。在很多情况下，两个部门使用的功能大多相同，使用的代码也大多相同。



- 可以看出，使用一个证书功能的集合比包含CA和RA这种直接建立在原始需求上的设计更简单、更有效、更灵活。
- 一个两层的CA方案允许HR和IT共享大多数相同的代码和协议。在这种情形下，差别主要是用户界面，仅需要增加几百行额外的代码，大大减少了系统负担。



- 在密钥管理中，PKI 不仅是起点，更是贯穿始终的核心要素：
 - 它是密钥管理的 "第一语言"，定义了数字信任的基础架构；
 - 它是行业认知的 "终极答案"，在反复实践中内化为自然的解决方案；
 - 它是破解难题的 "美妙愿景"，用系统化思维构建起密钥全生命周期管理的理想国。
- PKI 不仅构建了基于非对称加密算法的身份验证与数据完整性保护机制，更通过认证机构（CA）、证书管理系统（CMS）等组件的协同运作，形成跨行业、跨领域的安全信任共识机制。



- 基于量子密钥分发技术的PKI：量子密钥分发技术利用量子力学原理来实现密钥的安全分发，具有理论上的无条件安全性。将量子密钥分发技术与PKI相结合，可以为PKI系统提供更加安全的密钥管理，抵御量子计算带来的威胁，保障网络通信的长期安全性。
- 基于区块链技术的PKI：将区块链技术应用于PKI，可以改进数字证书的管理和验证方式。区块链上的数字证书信息更加透明和可信，无需依赖单一的CA机构，提高了PKI系统的安全性和可靠性，同时降低了信任风险。





- 基于人工智能技术的PKI：人工智能技术可以用于优化PKI系统的管理和安全防护。
- 例如，利用人工智能算法对PKI系统中的数据进行分析，实时监测系统的安全状态，及时发现潜在的安全威胁，并自动采取相应的防护措施，提高PKI系统的智能化水平和安全性能。



- **金融领域深化应用：**在金融领域，PKI将进一步应用于数字货币交易、金融机构间的安全通信、客户身份认证等方面。随着金融科技的发展，PKI技术将为金融业务提供更加全面的安全保障，确保金融交易的安全、高效进行，保护金融机构和客户的资金安全 and 信息安全。
- **政务领域全面覆盖：**电子政务将更加广泛地应用PKI技术，不仅用于政务文件传输和公民身份验证，还将拓展到政务数据共享、电子招投标、行政审批等多个环节。PKI技术将助力政务服务的数字化转型，提高政务工作的效率 and 安全性，增强政府与公民之间的信任。
- **企业领域多元化应用：**企业在内部网络安全、供应链管理、远程办公等方面将更多地依赖PKI技术。



2.随着零信任架构（Zero Trust）的普及，PKI的“梦想”是否会被颠覆？为什么？

谢谢大家
